

Assessment Report and Remediation Plan

Carin Madden
PNC CyberBootcamp 2026
September 10, 2026

Executive Summary

This vulnerability assessment was conducted to identify and prioritize security risks across the environment. The findings were reviewed based on severity, CVSS score, whether the vulnerability appears in the CISA Known Exploited Vulnerabilities (KEV) Catalog, and the importance of the affected system. Findings were also reviewed to determine whether they were true positives, false positives, or expected findings within the DVWA testing environment. The goal of this assessment is to identify the vulnerabilities that should be addressed first and recommend appropriate remediation or compensating controls.

Scope and Method

The assessment included the web server, application server, file server, domain controller, and DVWA test system. The scanner results were reviewed to identify vulnerabilities and security misconfigurations across these systems. Each finding ID was evaluated using a CVSS score, severity, affected system, detected software version, and KEV status. The detected versions were also compared with known affected versions to identify possible false positives. Findings were then prioritized based on their potential risk and impact to the environment. Findings were also given recommended remediations as well as compensating controls for anything that may not be able to be patched immediately.

Prioritized findings

In this section there is a google sheets of all findings prioritized by what I believe has the most precedence as well as ways to fix the vulnerabilities. Zoom in to 200% to read table.

#	Priority	Finding	System	#	CVSS	KEY	Vulnerability / Issue	Reason for Prioritizing	Fix
1	MTB-0001	MTB-WEB01		9.8	Yes		Apache Path Traversal/RCE - CVE-2021-42013	Critical CVSS, in KEY, and web-facing. The combin	Update Apache HTTP Server to 2.4.51 or more recent version
2	MTB-0009	MTB-APP01		9.8	No		vsftpd Backdoor - CVE-2011-2523	Critical CVSS. The affected vsftpd 2.3.4 version is	Upgrade software to patched release or stable version like vsftpd 2.3.5 or vsftpd 3.0.5
3	MTB-0003	MTB-WEB01		7.8	Yes		PowerKit Privilege Escalation - CVE-2021-4034	High CVSS, in KEY, and web-facing. An attacker w	Update the policykit-1 using the system package manager
4	MTB-0018	MTB-FILE01		8.1	N/A		SMB Signing Not Required	High CVSS and affects an internal file server. An	enable mandatory message signing in the Group policy
5	MTB-0025	MTB-DC01		8.8	Yes		ZeroLogon - CVE-2020-1472	High CVSS, in KEY, and affects the domain contro	apply the Microsoft security updates released in August 2020 and February 2021. Then enable full enforcement mode for netlogon secure channels
6	MTB-0019	MTB-FILE01		7.8	Yes		PowerKit Privilege Escalation - CVE-2021-4034	High CVSS and in KEY. An attacker with internal	Update the policykit-1 using the system package manager
7	MTB-0011	MTB-APP01		7.4	N/A		FTP Credentials Transmitted in Cleartext	High CVSS. FTP credentials are transmitted witho	add or update SSL/TLS settings and update the client connection specifically protocol and encryption so that it requires FTP over TLS
8	MTB-0004	MTB-WEB01		6.1	No		jQuery XSS - CVE-2020-11022	Medium CVSS, but the portal is internet-facing. TI	Upgrade to jQuery to version 3.5.0 or higher
9	MTB-0002	MTB-WEB01		7.5	Yes		Apache Path Traversal - CVE-2021-41773	High CVSS, in KEY, and affects the customer-facir	Update Apache HTTP Server to 2.4.51 or more recent version
10	MTB-0017	MTB-FILE01		7.5	N/A		Telnet Service - Cleartext Protocol	High CVSS. Telnet transmits usernames, password	Switch to encrypted alternative like SSH and close port 23
11	MTB-0010	MTB-APP01		7.5	N/A		FTP Anonymous Login Permitted	High CVSS. Anonymous FTP allows access witho	Disable anonymous access in FTP server configuration file
12	MTB-0028	MTB-DC01		6.5	N/A		Administrator Password Never Expires	Medium CVSS but affects the domain controller. /	Change the configuration in Local Users and Groups to have the administrator change password every 90 days
13	MTB-0026	MTB-DC01		5.9	N/A		RDP Weak Encryption Level	Medium CVSS and affects the domain controller	Enforce modern TLS and raise the minimum encryption strength in group policy
14	MTB-0027	MTB-DC01		5.3	N/A		SMBv1 Protocol Enabled	Medium CVSS. SMBv1 is an outdated protocol th	Disable SMBv1
15	MTB-0021	MTB-FILE01		5.3	N/A		SSH PermitRoot,login Enabled	Medium CVSS. Compromised root credentials co	Update the setting in SSH configuration file
16	MTB-0013	MTB-APP01		5.3	N/A		SSH PasswordAuthentication Enabled	Medium CVSS. Password authentication increase	disable password authentication in the Open SSH configuration files and restart the service
17	MTB-0005	MTB-WEB01		5.3	N/A		ServerTokens Full Information Disclosure	Medium CVSS and web-facing. Exposed Apache i	Change the configuration directives in the Apache configuration file to hide the server's version and any other sensitive OS details
18	MTB-0020	MTB-FILE01		5	N/A		SMB Null Session Enumeration	Medium CVSS. Could allow unauthorized intern	Configure Windows Security Policies to block unauthorized anonymous access to SAM accounts, shares, and named pipes
19	MTB-0006	MTB-WEB01		3.7	N/A		Web Server Directory Listing Enabled	Low CVSS but web-facing. Directory listing could	Disable the indexing configuration
20	MTB-0007	MTB-WEB01		3.7	N/A		SSH Weak MAC Algorithms	Low CVSS but affects an externally accessible sy	Define a list of secure MAC algorithms in the SSH daemon config file
21	MTB-0029	MTB-DC01		3.3	N/A		Defender Real-Time Protection Disabled	Low CVSS but affects the domain controller. Disal	Use elevated powershell command to re-enable monitoring
22	MTB-0022	MTB-FILE01		2.4	N/A		World Writable Files in /opt	Low CVSS and requires existing access. A local	fix file permissions

False Positives

In this section there is a google sheets of all false positives, and true positives found in test environments, my reasoning for why they are false positives evidence.

Finding	What the Scanner Saw	Why I Think It's a False Positive / Expected Finding	Evidence
MTB-0001	SQL Injection in Application Parameter - Apache 2.4.52 / PHP 8.1	This is a DVWA test application that is deliberately vulnerable to attacks such as SQL injection.	The finding is expected in this testing environment and is not on a production application. Technically, this is an expected true positive rather than a false positive.
MTB-0032	OS Command Injection in Application Parameter - Apache 2.4.52 / PHP 8.1	DVWA is intentionally designed to allow vulnerabilities such as command injection for security i	The finding is expected in this lab environment. Technically, this is an expected true positive rather than a false positive.
MTB-0033	Unrestricted File Upload Permitted - Apache 2.4.52 / PHP 8.1	DVWA intentionally allows insecure features for testing. Unrestricted file uploads are expecte	Unrestricted file uploads are expected in this non-production test application. This is an expected true positive rather than a false positive.
MTB-0034	Reflected Cross-Site Scripting (XSS) - Apache 2.4.52 / PHP 8.1	Reflected XSS is intentionally present in DVWA so users can practice identifying and testing we	This is expected in the test environment. This is an expected true positive rather than a false positive.
MTB-0035	Session Cookie Missing HttpOnly and Secure - PHP 8.1	The missing cookie protections are expected because DVWA is deliberately configured with we	This would be a security concern on a production application. This is an expected true positive rather than a false positive.
MTB-0036	Login Form Served Over Plain HTTP - Apache 2.4.52	DVWA is a non-production test application that is deliberately insecure.	
MTB-0037	HTTP TRACE Method Enabled - Apache 2.4.52	TRACE is enabled on the deliberately vulnerable DVWA test server.	
MTB-0024	CVE-2019-0708 - Remote Desktop Services RCE (BlueKeep) - Windows Server 2019	The scanner detected BlueKeep, but the evidence shows the system is Windows Server 2019.	This is acceptable for the isolated testing environment but should normally be disabled in production. This is an expected true positive rather than a false positive.
MTB-0016	CVE-2017-7484 - SambaCry RCE - Samba 4.15.13	The scanner detected SambaCry, but the installed version is Samba 4.15.13.	The affected Windows versions identified in my research do not include Server 2019, so I believe the CVE detection is a false positive.
MTB-0012	CVE-2014-6271 - GNU Bash Shellshock RCE - GNU Bash 5.1.16	The scanner detected Shellshock, but the evidence shows GNU Bash 5.1.16.	This is newer than the vulnerable versions identified in my research, so I believe this is a false positive.
MTB-0014	CVE-2023-4911 - glibc Looney Tunables - glibc 2.35	The scanner detected glibc 2.35 as vulnerable, but Ubuntu patched this vulnerability in its packa	The installed Ubuntu package contains the security fix, so I believe this is a false positive.

Compensating Controls

In this section there is a google sheets of compensating controls for eight vulnerabilities that have precedence but might not be able to be immediately patched.

Finding	Instances	Compensating Controls
MTB-0001 - Apache CVE-2021-42013	If Apache cannot immediately be upgraded	Use a firewall or WAF to limit suspicious web traffic, monitor Apache logs until the server can be upgraded
MTB-0009 - vsftpd Backdoor	If the FTP server cannot immediately be upgraded/replaced	Restrict FTP access to trusted IP addresses, block unnecessary FTP traffic with the firewall, and monitor port 6200 for suspicious connections until vsftpd can be upgraded
MTB-0003 / MTB-0019 - PowerKit	If PolicyKit cannot immediately be patched	Limit user access, monitor for suspicious privilege escalation, temporarily restrict plexexec until it can be patched
MTB-0025 - ZeroLogon	If the domain controller patch cannot immediately be deployed	Limit access to the domain controller using firewall rules, keep it separated from untrusted systems, monitor netlogon activity until the updates can be installed
MTB-0011 - FTP Cleartext Credentials	If FTP cannot immediately be migrated to FTPS/SFTP	Restrict FTP to a protected network/VPN, firewall access to trusted hosts, avoid privileged credentials until FTPS or SFTP can be configured
MTB-0017 - Telnet	If a legacy system requires Telnet temporarily	Monitor connections on port 23 and limit access to trusted IP addresses, and require a VPN for remote access until it can be replaced with SSH
MTB-0027 - SMBv1	If a legacy application/device still depends on SMBv1	Limit SMB traffic to only systems that need it with firewall rules and isolate the systems that still require SMBv1 until the protocol can be disabled

Recommended Cadence

For this specific environment I recommend scanning weekly. Weekly scans can help identify new vulnerabilities, configuration issues, or changes to the systems before they become a larger security risk. Specifically weekly scans should prioritize the domain controller as well as any internet facing systems. I also recommend performing additional scans when necessary. Such as after major updates, configuration changes, or remediation.

Link to google sheets

 Week 6 day 1-3 lab

There are tabs on the bottom that specify my work throughout the lab/assessment.

Disclaimer: ChatGPT was used to reword sentences and for formatting of this report.